

# Relatório de Laboratório — Mini SOC

Simulação de Ataques, Detecção e Resposta com Splunk + Sysmon

Autor: Leonardo Garcia Santos

GitHub: [github.com/leonardogsantos](https://github.com/leonardogsantos) | LinkedIn: [linkedin.com/in/leonardo-garcia-santos-a81a5a1b4](https://www.linkedin.com/in/leonardo-garcia-santos-a81a5a1b4)

**Data:** 04 / 10 / 2026

## 1. Objetivo do Laboratório

Este relatório documenta a construção de um ambiente de SOC (Security Operations Center) em miniatura, utilizado para simular técnicas comuns de ataque, detectá-las por meio de buscas SPL (Search Processing Language) no Splunk, e demonstrar o fluxo completo de coleta de log, detecção e investigação.

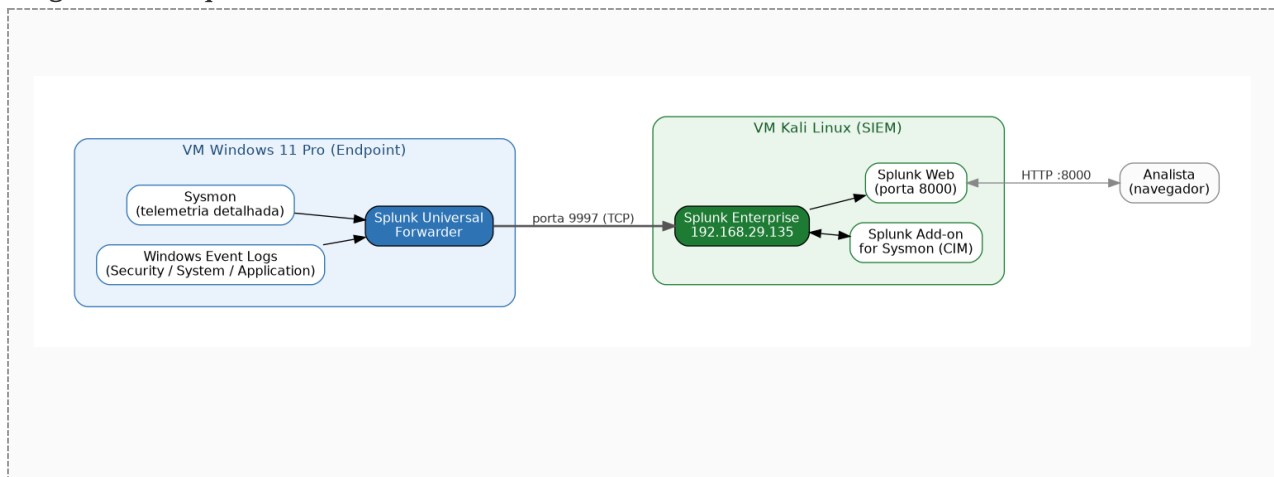
O objetivo é demonstrar, na prática, competências de coleta de telemetria de endpoint, engenharia de detecção e análise de eventos de segurança — habilidades centrais para a posição de Analista de segurança da informação júnior.

## 2. Arquitetura do Ambiente

O ambiente foi construído com duas máquinas virtuais (VMware Workstation), simulando um endpoint monitorado e um servidor SIEM central:

- Kali Linux — hospeda o Splunk Enterprise (SIEM), responsável por indexar, armazenar e analisar os eventos recebidos. IP: 192.168.29.135, porta 8000 (Web) e 9997 (recebimento de dados).
- Windows 11 Pro — endpoint monitorado, com Splunk Universal Forwarder (coleta e envio de Windows Event Logs: Security, System, Application) e Sysmon (telemetria detalhada de criação de processos, conexões de rede e mais).
- Splunk Add-on for Sysmon (oficial, Splunk LLC) — instalado na Kali para normalizar e extrair corretamente os campos dos eventos do Sysmon (Image, CommandLine, User, etc.), seguindo o Common Information Model (CIM).

Diagrama da arquitetura:



## 3. Cenários Simulados e Detecções

Foram simulados três cenários de ataque comuns, cada um gerando eventos reais nos logs, seguidos da criação de uma query de detecção correspondente.

### Cenário 1 — Força Bruta (Brute Force) de Credenciais

### O que foi feito:

Foram realizadas 5 tentativas de logon na VM Windows utilizando senha incorreta propositalmente, seguidas de uma tentativa com a senha correta, simulando um ataque de adivinhação de credenciais.

### Técnica MITRE ATT&CK:

T1110 — Brute Force

### Evento gerado (Event ID):

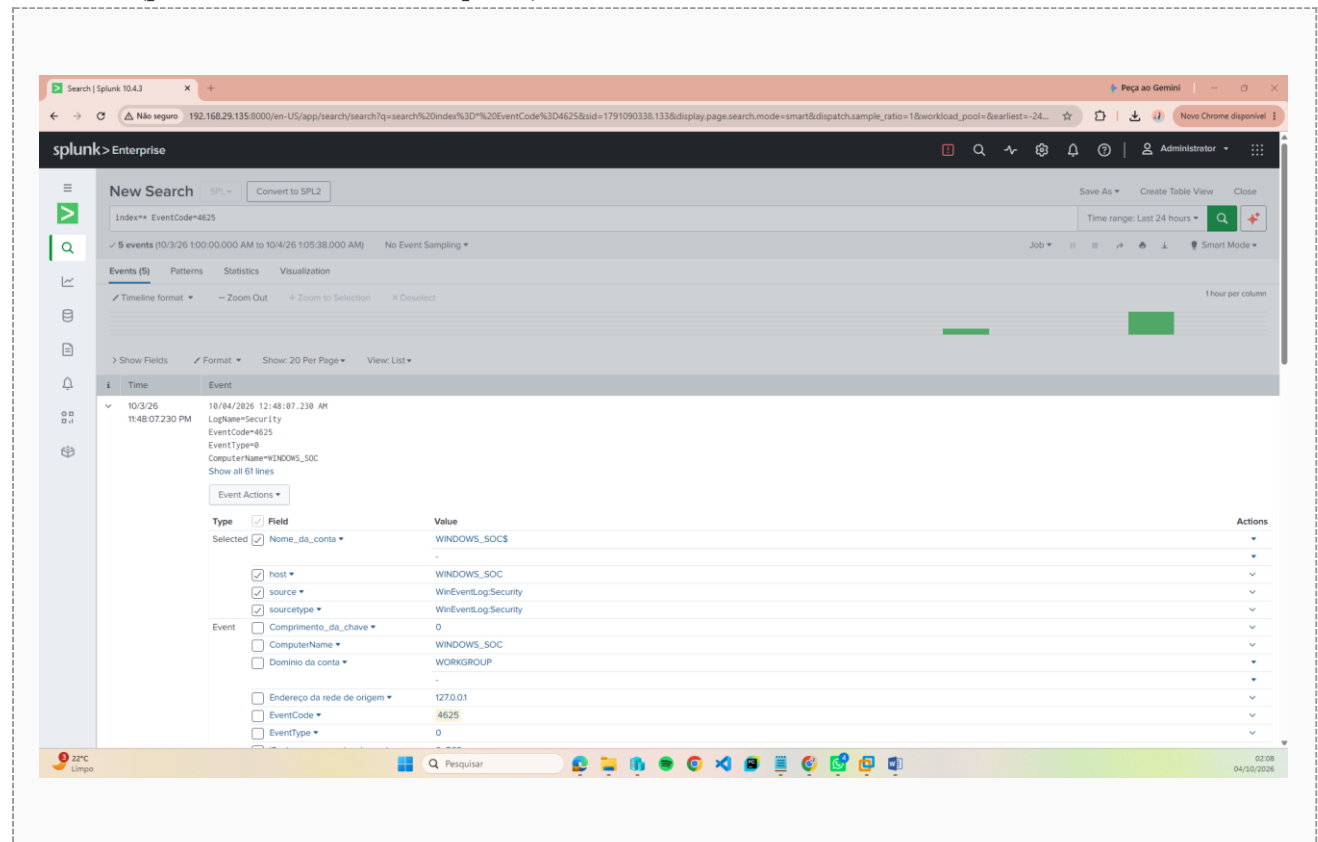
EventCode 4625 (Logon Failure) × 5, seguido de EventCode 4624 (Logon Success)

### Query SPL de detecção:

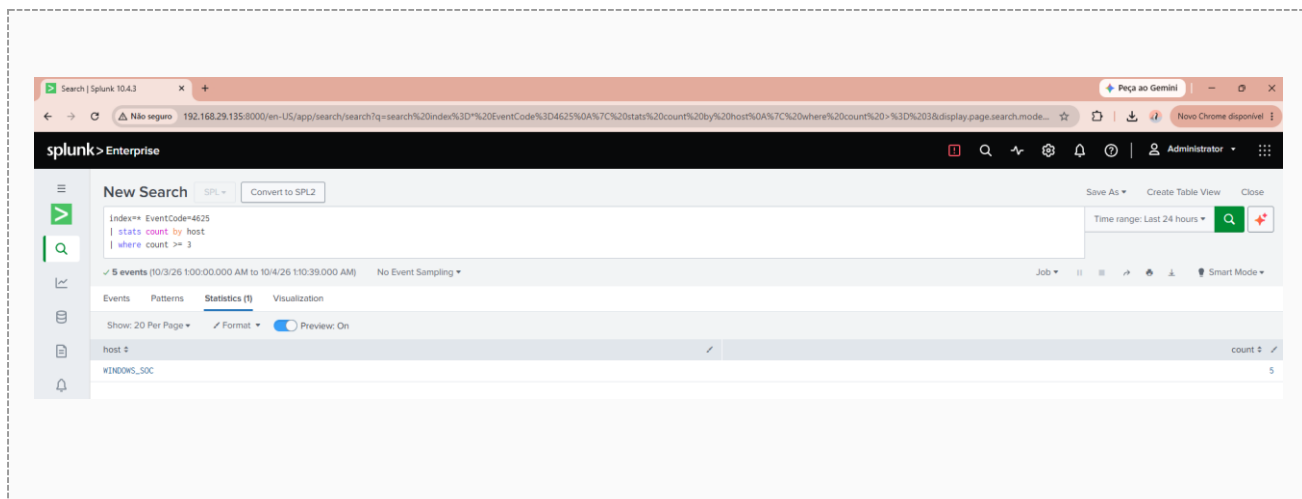
```
index=* EventCode=4625
| stats count by host
| where count >= 3
```

A query agrupa as falhas de logon por host e isola os casos com 3 ou mais tentativas — limiar comum para identificar comportamento de força bruta.

### Evidência (print do evento bruto no Splunk):



### Evidência (print da query de detecção com resultado):



## Cenário 2 — Execução de PowerShell Ofuscado (Base64)

### O que foi feito:

Foi executado um comando PowerShell utilizando o parâmetro `-enc`, que recebe instruções codificadas em Base64 — técnica comumente usada por atacantes para evitar detecção por assinatura e dificultar a análise do comando real.

### Técnica MITRE ATT&CK:

T1059.001 — PowerShell / T1027 — Obfuscated Files or Information

### Evento gerado (Event ID):

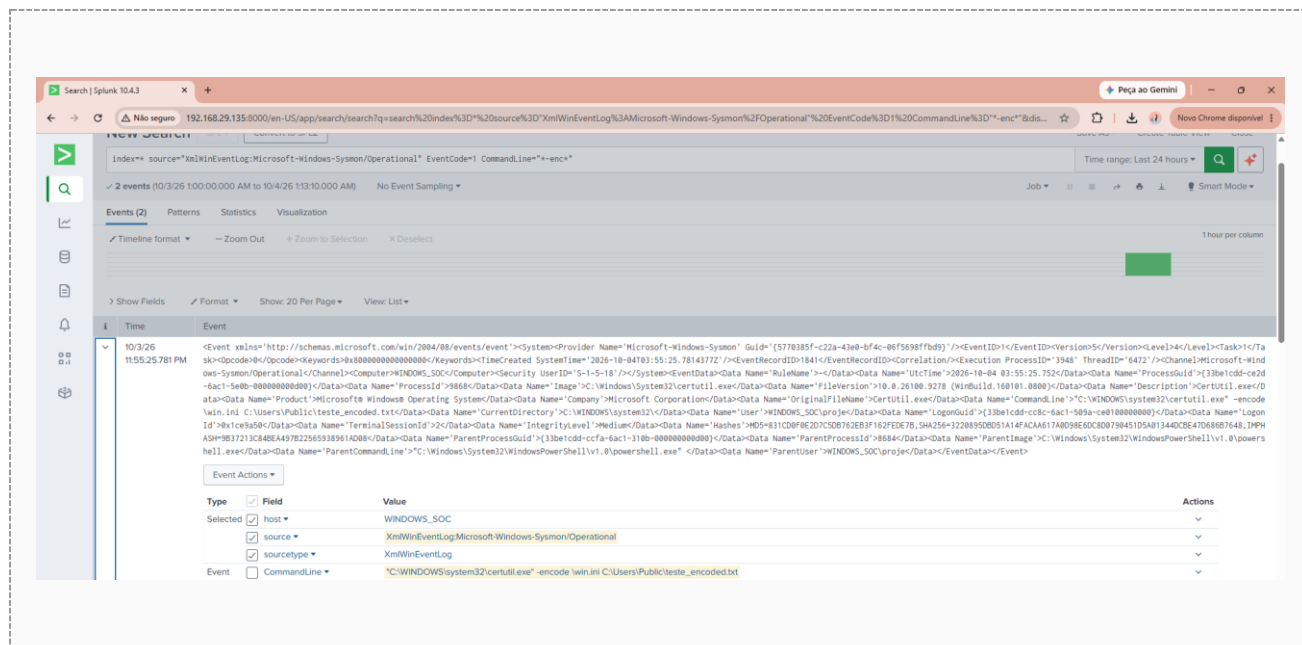
EventCode 1 (Process Create) do Sysmon, contendo `'-enc'` na CommandLine

### Query SPL de detecção:

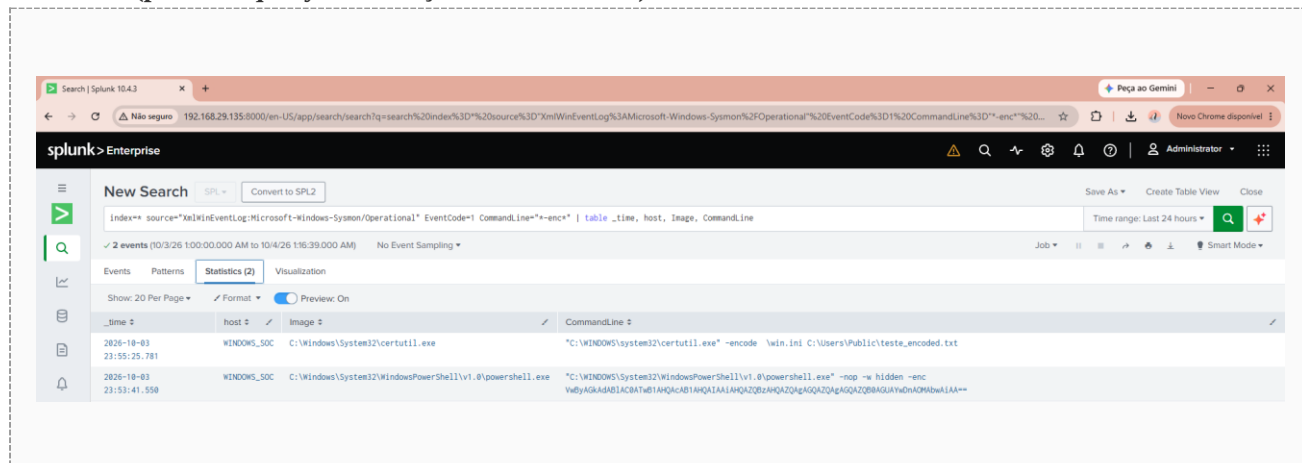
```
index=* source="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1  
CommandLine="*-enc*" | table _time, host, Image, CommandLine
```

A query busca, entre os eventos de criação de processo do Sysmon, qualquer linha de comando contendo a flag `-enc`, revelando o uso de comandos ofuscados.

### Evidência (print do evento bruto no Splunk):



## Evidência (print da query de detecção com resultado):



## Cenário 3 — Abuso de Binário Legítimo do Windows — LOLBin (certutil.exe)

### O que foi feito:

Foi utilizado o `certutil.exe`, ferramenta nativa e legítima do Windows, para codificar um arquivo em Base64 — a mesma técnica usada por atacantes reais para transferir ou ofuscar payloads sem levantar suspeita óbvia (técnica conhecida como Living Off The Land).

### Técnica MITRE ATT&CK:

T1140 — Deobfuscate/Decode Files or Information / T1105 — Ingress Tool Transfer

### Evento gerado (Event ID):

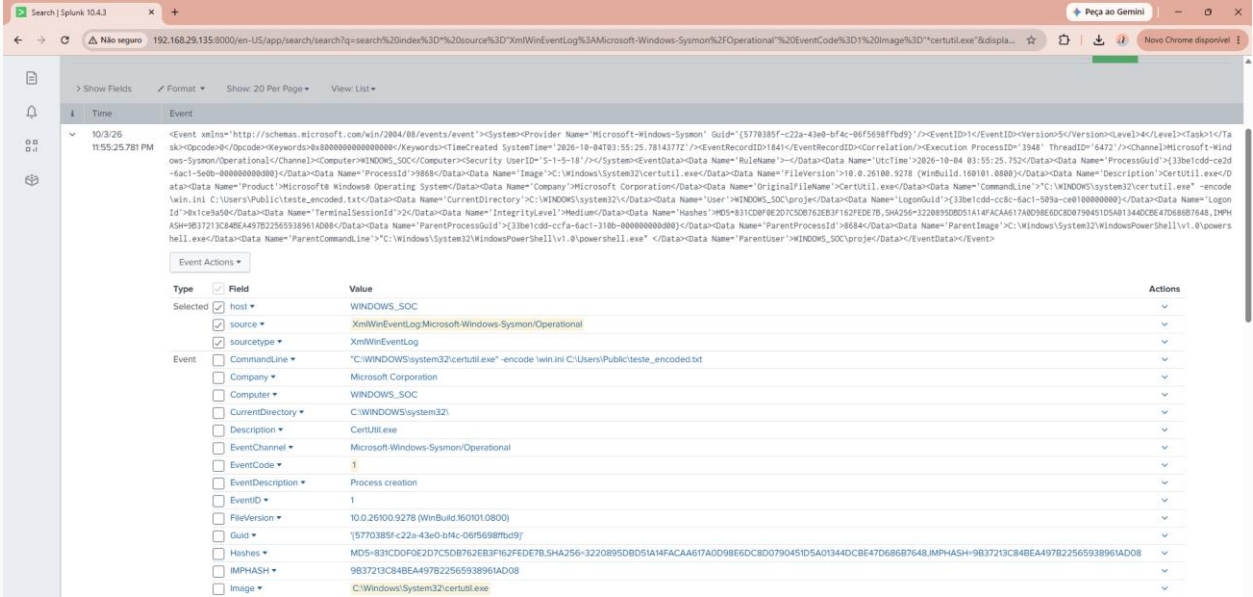
EventCode 1 (Process Create) do Sysmon, com Image = `certutil.exe`

### Query SPL de detecção:

```
index=* source="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1  
Image="*certutil.exe"  
| table _time, host, User, CommandLine
```

Isola toda execução do certutil.exe, permitindo análise manual da linha de comando utilizada — essencial, já que esse binário tem usos legítimos e maliciosos.

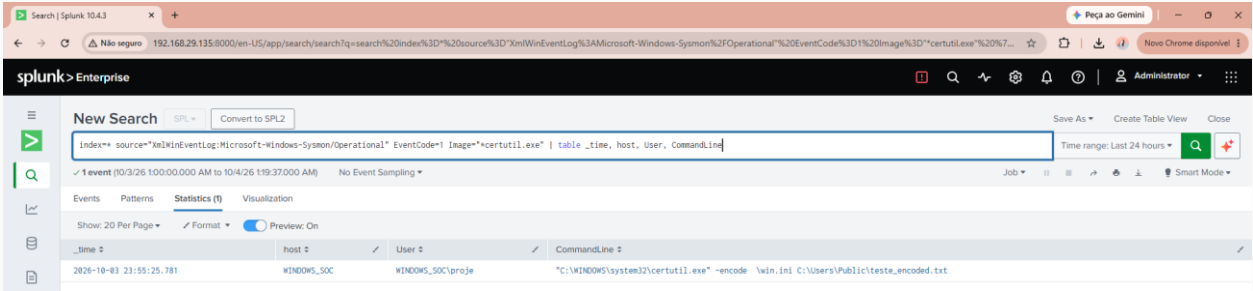
**Evidência (print do evento bruto no Splunk):**



The screenshot shows a Splunk search result for a Windows Sysmon event. The event details are as follows:

| Type    | Field                            | Value                                                                                                                                         | Actions |
|---------|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|---------|
| Event   | host                             | WINDOWS_SOC                                                                                                                                   |         |
|         | source                           | XmlWinEventLog:Microsoft-Windows-Sysmon/Operational                                                                                           |         |
|         | sourcetype                       | XmlWinEventLog                                                                                                                                |         |
|         | CommandLine                      | "C:\WINDOWS\system32\certutil.exe" -encode 'win.ini C:\Users\Public\teste_encoded.txt                                                         |         |
|         | Company                          | Microsoft Corporation                                                                                                                         |         |
|         | Computer                         | WINDOWS_SOC                                                                                                                                   |         |
|         | CurrentDirectory                 | C:\WINDOWS\system32\                                                                                                                          |         |
|         | Description                      | CertUtil.exe                                                                                                                                  |         |
|         | EventChannel                     | Microsoft-Windows-Sysmon/Operational                                                                                                          |         |
|         | EventCode                        | 1                                                                                                                                             |         |
|         | EventDescription                 | Process creation                                                                                                                              |         |
|         | EventID                          | 1                                                                                                                                             |         |
|         | FileVersion                      | 10.0.26100.9278 (WinBuild.160101.0800)                                                                                                        |         |
|         | Guid                             | {5770385f-c22a-43e0-bf4c-06f5698fbdb5}                                                                                                        |         |
|         | Hashes                           | MD5=831CD0F0E2D7C5D8762E3F62FED7B.SHA256=32208950BD51AFACAA617A0D9E6DC8D0790451D5A0134DCBE47D686B7648.MPHASH=9B37213C84BEA497B22565938961AD08 |         |
| IMPHASH | 9B37213C84BEA497B22565938961AD08 |                                                                                                                                               |         |
| Image   | C:\Windows\System32\certutil.exe |                                                                                                                                               |         |

**Evidência (print da query de detecção com resultado):**



The screenshot shows a Splunk search interface with the following query and results:

**Search Query:** `index=* source="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 Image="*certutil.exe" | table _time, host, User, CommandLine`

**Results:**

| _time                   | host        | User              | CommandLine                                                                           |
|-------------------------|-------------|-------------------|---------------------------------------------------------------------------------------|
| 2026-10-01 23:55:25.781 | WINDOWS_SOC | WINDOWS_SOC\proje | "C:\WINDOWS\system32\certutil.exe" -encode 'win.ini C:\Users\Public\teste_encoded.txt |

## 4. Alertas Configurados

Além das buscas pontuais, as cinco detecções foram salvas como Alerts no Splunk, configurados para rodar automaticamente a cada 15 minutos, simulando um processo de monitoramento contínuo (equivalente a regras de correlação em um SIEM corporativo).

### Print do painel de alertas configurados:

| Name                                                                                                                                                                                                                                      | Actions              | Type  | Next Scheduled Time     | Display View | Owner | App    | Alerts | Sharing | Status    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|-------|-------------------------|--------------|-------|--------|--------|---------|-----------|
| Alerta - Brute force<br>Detecta 3 ou mais tentativas de login falhadas no mesmo host, indicando possível ataque de força bruta                                                                                                            | Edit Run View Recent | Alert | 2026-10-05 06:00:00 EDT | none         | admin | search | 0      | Private | ✓ Enabled |
| Alerta - Indicadores de PowerShell Ofuscado<br>Agrega múltiples indicadores de ofuscação em linha de comando (esp. -w hidden, -enc, -bypass), comumente usados em técnicas de evasão de defesa                                            | Edit Run View Recent | Alert | 2026-10-05 06:00:00 EDT | none         | admin | search | 0      | Private | ✓ Enabled |
| Alerta - Possível conta comprometida após brute force<br>Correlaciona tentativas de login falhadas seguidas de um login bem-sucedido no mesmo host dentro de 5 minutos, indicando que um ataque de força bruta pode ter sido bem-sucedido | Edit Run View Recent | Alert | 2026-10-05 06:00:00 EDT | none         | admin | search | 0      | Private | ✓ Enabled |
| Alerta - PowerShell com comando codificado<br>Detecta execução de processos com a flag -enc na linha de comando, indicando possível uso de PowerShell ofuscado para evitar detecção técnica MITRE ATT&CK T1055.005                        | Edit Run View Recent | Alert | 2026-10-05 06:00:00 EDT | none         | admin | search | 0      | Private | ✓ Enabled |
| Alerta - Uso de certutil &OJBJr<br>Detecta execução do console.exe, binário legítimo do Windows frequentemente abusado por atacantes para codificar/decodificar e baixar arquivos (técnica MITRE ATT&CK T1047.010)                        | Edit Run View Recent | Alert | 2026-10-05 06:00:00 EDT | none         | admin | search | 0      | Private | ✓ Enabled |

## 5. Conclusão

Este laboratório demonstrou, de ponta a ponta, o fluxo de um ambiente de monitoramento de segurança: coleta de telemetria de endpoint (Windows Event Logs + Sysmon), ingestão centralizada em um SIEM (Splunk Enterprise), normalização de dados via Technology Add-on oficial, e engenharia de detecção utilizando SPL para identificar técnicas mapeadas no framework MITRE ATT&CK.

Entre os principais aprendizados práticos obtidos, destacam-se: configuração de coleta remota de logs via Universal Forwarder, parsing de eventos XML do Sysmon, escrita de queries de correlação (transaction, stats), e o processo de troubleshooting de uma arquitetura distribuída ponta a ponta.

### 5.1 — Próximos passos / melhorias futuras

- Adicionar mais fontes de log (ex: Sysmon com regras customizadas para detecção de persistência — chaves de Registro, tarefas agendadas).
- Criar um Dashboard consolidado no Splunk reunindo as 5 detecções em um único painel visual.
- Simular técnicas adicionais do MITRE ATT&CK (ex: T1053 — Scheduled Task, T1547 — Boot or Logon Autostart Execution).
- Explorar uma ferramenta de simulação de adversário mais estruturada, como o Atomic Red Team, para cobrir mais técnicas de forma padronizada.
- Avaliar a integração com um componente de resposta automatizada (SOAR), mesmo que simplificado.

*Repositório do projeto: [github.com/leonardogsantos/mini-soc-splunk](https://github.com/leonardogsantos/mini-soc-splunk)*